安全自评报告

权限分级、资金约束与已知风险

本报告为开发者自评，范围限于本地模拟银行与当前代码快照。以身份与授权分离、后端逐次复核、事务与幂等、未知结果暂停为核心，列明实现证据、验证范围及未关闭风险。它不是第三方审计或金融合规认证。

版本	说明
编制日期	2026-10-30（Asia/Shanghai）
交付状态	评审稿 v1.1；基于本地未提交工作树，不代表正式提交完成
代码基线	2b63eba；分支 codex/payees-transfer-workflow
适用范围	虚构账户、资金与联系人；Windows 本地单机单进程演示
证据边界	222项自动化已通过；列示人工用例已由项目负责人审核通过

阅读导引

02 资产与信任边界 · 03 权限分级与认证 · 04 资金安全与故障 · 05 模型与数据保护 · 06 验证证据 · 07 风险清单与提交核对

02 / 评估范围与信任边界

资产	信任与保护目标
用户身份、会话与密码	防止冒用、跨用户访问和授权继承；密码不进入模型或材料
虚构资金、账本与操作	金额平衡、不超额、不重复扣款；回执来源可核对
授权、任务与步骤	执行限定对象、范围、金额、期限和顺序；刷新/重启不扩大权限
账单、备注与订阅证据	按归属查询；不可信数据不能变成指令或浏览器脚本
模型与云端追踪	独立外部边界；配置决定数据是否发送，不能代替交易事实

数据流与角色

浏览器经同源请求访问FastAPI，服务端从会话解析用户。Agent读取被允许的本人数据并向配置的HTTPS模型发起请求；工具提出业务意图，经应用和Bank检查后写入SQLite。人工批准和授权创建来自独立页面操作。

数据库与服务端运行环境是受信基础。模型输出、用户聊天、商户文本、备注、供应商响应和客户端字段均作为不可信输入处理。模型提出意图不产生新的身份或权限。

不在本轮结论内

真实资金通道、供应商内部数据治理、真实手机设备、公网TLS、高可用与灾备、第三方渗透测试和监管合规均未验收。测试通过不能推出不存在未知缺陷。

依据：src/ai_banking/app.py、auth/__init__.py、agent.py、banking/service.py；详细部署边界见deployment-guide.md。

03 / 权限分级与身份认证

层级	允许能力	强制条件
未登录	登录与有限健康信息	业务查询和操作不可访问
已登录	本人查询、预览与意图准备	会话解析身份；归属不从模型/请求体接受
密码复核	创建授权、显式载入联系人、编辑备注等受保护页面动作	重新验证当前账号密码；登录不自动授予资金权限
逐笔人工批准	批准原操作及原参数	会话绑定挑战、参数摘要、有效期、明确approve/reject
明确预授权	用户选定范围内逐次执行	账户、对象、操作、单笔/累计、最低余额、期限和身份版本复核

订阅候选登记要求用户核对证据并显式勾选确认，不将其混写为“所有登记动作都要求密码复核”。登记不扣款、不授予权限。

认证与请求控制

Argon2id存储密码哈希；会话令牌在数据库中保存摘要。登录轮换会话，重置密码或停用可使相关身份版本失效。Cookie设HttpOnly和SameSite；Secure随本地HTTP例外配置。默认空闲900秒、绝对28800秒会话期限。

请求执行Origin、Host、CSRF与JSON类型约束，并有登录限流和32KB请求体边界。确认挑战必须绑定当前会话及准确参数；聊天中的“同意”不代替独立批准。

依据：auth/__init__.py、app.py、banking/api.py；tests/test_application.py、test_banking_edges.py。

04 / 资金不变量与故障处置

不变量	控制与失败行为
整数与平衡	金额为整数分、CNY；模拟转账双边金额相反、绝对值相等；余额与账本同事务提交
不可超额	准备预占时：spent + reserved + cost ⩽ limit；cost ⩽ single；余额扣其他预占及本次支出后不低于minimum
稳定幂等	任务/步骤/参数绑定；同标识不同参数拒绝；回查原编号而非新建付款
未知结果保守处理	outcome_unknown保留预占，相关账户/授权的新支出暂停；核查原操作，不盲重试
联动流程约束	预览摘要复核；步骤顺序和参数在准备事务中验证，禁止跳步或新编号重放
业务独立性	取消不退款，未来节省不当现金；前一步成功不因后一步失败自动回滚

人工与预授权共用执行器

awaiting_confirmation经有效挑战批准后进入authorized；预授权通过策略复核后可进入authorized。执行路径为authorized → executing → succeeded，明确失败进入failed，拒绝为rejected，到期为expired；中断或无法确认时进入或保留outcome_unknown。

应用禁止并行绕过任务未完成步骤。收入不会补回累计授权额度；更换对话、退出或重启也不重置已花费和预占。新载入联系人不扩展旧授权。

依据：banking/service.py、workflows.py；tests/test_banking.py、test_banking_edges.py、test_transfer_workflows.py。

05 / 模型风险与数据保护

风险入口	已有控制	残余问题
提示注入 / 恶意备注	类型化工具、转义、身份和授权后端强制校验	在有效授权范围内仍可能产生不符合用户本意的意图
歧义 / 目标丢失	同名候选需澄清、原参数确认、方案绑定	列示澄清用例已人工审核；扩展样本持续回归
供应商未完成 / 协议异常	明确失败，不静默离线替代；未完成响应不执行其工具	可能中断交互；需结合实际供应商预算验证
历史压缩	固定约束保留、摘录预算、状态回填、超预算停写	确定性摘录有损；启发式token数未校准
前端外部文本	安全Markdown子集与转义，不执行工具文本中的脚本	未做独立完整无障碍或前端渗透审计

第三方数据最小化与开关

模型模式发送问题、历史和本人模拟财务数据，使用HTTPS；密码、认证Cookie和CSRF不进入模型消息。store=false是应用请求参数，不能作为供应商零保留保证。供应商政策需独立核实。

终端轨迹默认开启但正文默认关闭。AGENT_TRACE_CONTENT=false隐藏内容，AGENT_TRACE_ENABLED=false关闭自定义轨迹。云追踪LANGSMITH_TRACING默认false，LANGSMITH_TRACE_CONTENT默认false；云端开关独立。追踪可失败或丢失，不能作为可靠资金账本。

材料与源码交付

归档排除.env、数据库、虚拟环境、日志、浏览器会话与实际凭据。常见密钥格式扫描无命中只代表有限模式检查，仍须人工复核。仅以合成数据录屏和演示，不把真实密钥粘贴进网页或文档。

06 / 测试证据与结论限度

验证面	现有证据	结论限制
身份 / 请求边界	test_application：CSRF、Origin/Host、会话、限流、归属	自动化不是独立渗透测试
授权与挑战	test_banking_edges：会话绑定、摘要、期限、重置失效	人工仍须核对收款对象和金额
并发与一致性	test_banking：余额/预算争用、回滚、响应丢失、重启	仅单机模拟执行器，不是跨银行一致性
分析与候选	test_insights：完整区间、证据变化、重复/并发登记	启发式规则不证明欺诈或闲置
固定方案	test_transfer_workflows：顺序、对象、金额、重放、停止	不是任意任务规划器能力评测
上下文	test_context：预算、摘要、固定状态与停写	不能证明长对话意图无损

已记录结果

现有完整回归222项通过，日志记录31.83秒，Ruff lint与36文件格式检查通过。参数化节点计数为测试项，不当作222条真实模型业务任务。

历史36条真实模型固定样本，35条结构检查通过；1条耗尽输出预算被保护拦截，无扣款。提高输出预算后的3次诊断不替代原失败。留出样本已用于诊断，不再是未见验证。

本次14张功能图使用独立虚构数据库和明确标记的脚本化Agent，工具与执行器实际运行，不能作为新的真实模型成功样本。新增联系人和固定方案的列示人工用例已由项目负责人确认审核通过。

本次对源码ZIP隔离解压后复测222项通过（40.14秒），使用本机已有依赖；不代表干净环境重新安装验收。原日志保留在source-archive-pytest.txt。

人工审核记录：审核人角色为项目负责人，日期2026-10-30；test-cases.md中MAN-01至MAN-10的审核结论为通过。人工审核与自动化回归共同支撑功能验证；历史模型评测仍按原样本与原结果记录。

复核入口：配套test-cases.md、evidence/pytest.txt、docs/agent-evaluation-results.md。

07 / 已知风险与提交核对

等级为本项目自评优先级：高表示可能导致授权范围内误操作或阻止公开部署；中表示影响判断、可用性或验证可信度。未标零风险。

风险 / 级别	已有缓解	仍需完成
授权内意图误解 / 高	人工默认、对象范围和固定方案约束	列示人工用例已审核；继续补充独立回归样本
本地短密码与HTTP / 高	Argon2id、限流、仅显式回环例外	公网前重新设计认证、TLS与会话部署
日志 / 外部数据 / 中	正文和追踪可关闭；凭据不进模型	演示前检查开关，核实供应商保留规则
未知结果与部分成功 / 中	保留预占、原编号回查、停止后续	人工故障恢复演练与说明
规则误报漏报 / 中	公开条件与流水、显式登记	不承诺欺诈识别或闲置订阅准确率
上下文损失 / 中	状态回填、预算不足停写	列示目标变更用例已人工审核；持续回归
工作树与远程差异 / 中	源码快照、文件清单与归档哈希	冻结提交、队友审查并重新打包
可复现性与部署 / 中	锁文件、测试、明确本机步骤	全新环境安装、最低Python版本复测

提交前核对

1. 补齐团队、责任人和审查记录，不编造签名。
2. 保留人工审核记录，完成冻结版本的最终试讲。
3. 冻结代码版本，确认源码包、文档、截图一致。
4. 在干净环境安装并执行配套测试。
5. 复核敏感信息与文件格式后再上传。

自评结论：本地竞赛原型已形成受控资金闭环，222项自动化通过，列示人工用例由负责人审核通过。评估范围为本地模拟环境；公网部署、监管认证和第三方审计属于独立验证事项。